

Martins
BTS SIO
Nathan

5 - Protection du serveur web



Sommaire :

Partie A :	2
Partie B :	7
Partie C — Gestion des sauvegardes	11

Partie A :

1) On souhaite **protéger le serveur webftp** en le plaçant dans un réseau de classe A, non visible par les utilisateurs.

Quel vont être les modifications à apporter au réseau de GSB ?

Le passage d'une architecture à plat (Flat Network) vers une architecture segmentée nécessite l'introduction d'un élément de routage.

Segmentation Réseau : Création d'un sous-réseau privé "étanche" (segment LAN ou réseau interne) pour le serveur.

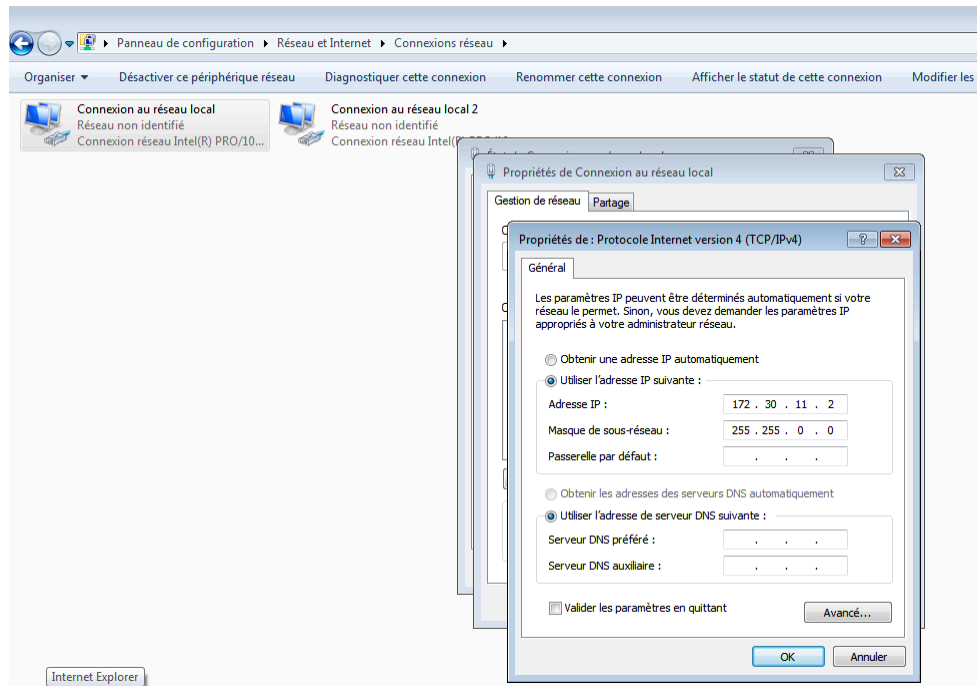
Implémentation d'une Passerelle : Mise en place d'une machine intermédiaire (VM Routeur) possédant deux interfaces réseau (dual-homed) pour faire le pont entre le réseau utilisateur (172.30.x.x) et le réseau serveur (10.0.0.x).

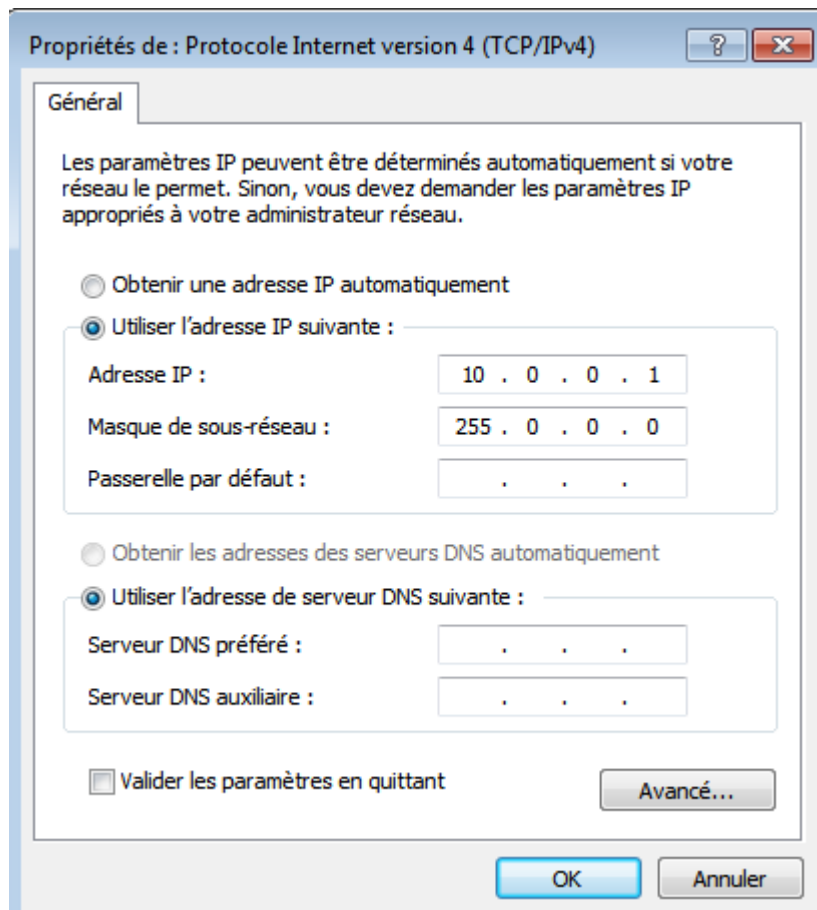
Plan d'adressage IP :

Entité	Rôle	Interface 1 (Externe/WAN)	Interface 2 (Interne/LAN)
PC Hôte	Client / Administrateur	172.30.11.1 (Physique)	N/A
VM 1	Routeur / Passerelle	172.30.11.2 (Pont/Bridge)	10.0.0.1 (Réseau interne)
VM 2	Serveur Web/FTP	N/A	10.0.0.10 (Réseau interne)

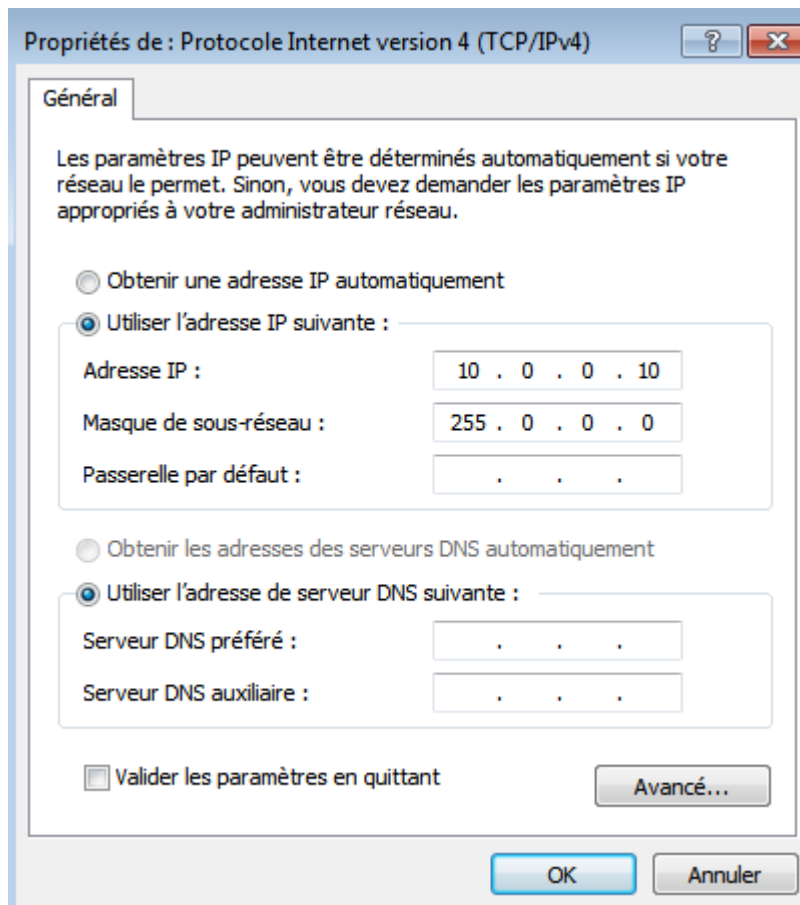
2) Mettre en place ces modifications.

VM 1 :





VM 2 :



PC Hôte :

J'ai ajouter cette ligne de commande en CMD Admin , afin que le pc hôte connaisse le réseaux 10.0.0.0

```
C:\> Administrateur : Invite de commandes

Microsoft Windows [version 10.0.17763.8511]
(c) 2018 Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>route add 10.0.0.0 mask 255.0.0.0 172.30.11.2
OK!

C:\Windows\system32>
```

3) Effectuer une phase de tests pour vérifier le bon fonctionnement du serveur webftp, pour toutes les catégories d'utilisateurs



Ping du PC Hote vers la VM 2(serveurs)

```
Administrator: Invite de commandes
C:\Windows\system32>ping 10.0.0.1

Envoi d'une requête 'Ping' 10.0.0.1 avec 32 octets de données :
Réponse de 10.0.0.1 : octets=32 temps<1ms TTL=127
Réponse de 10.0.0.1 : octets=32 temps<1ms TTL=127
Réponse de 10.0.0.1 : octets=32 temps<1ms TTL=127
Réponse de 10.0.0.1 : octets=32 temps<1ms TTL=127

Statistiques Ping pour 10.0.0.1:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
Durée approximative des boucles en millisecondes :
    Minimum = 0ms, Maximum = 0ms, Moyenne = 0ms

C:\Windows\system32>
C:\Windows\system32>_
```

Cependant afin de pouvoir ping et accéder au site, j'ai dû désactiver le proxy de Firefox, puis désactiver le pare-feu de chaque VM.

Détails techniques pour votre rapport :

Le Visiteur : C'est l'utilisateur standard (médecin, visiteur médical). Son flux réseau est limité aux ports **80** et **443**. Il ne voit jamais l'arborescence du serveur.

Le Développeur : Il utilise un compte spécifique qui est "emprisonné" (Chroot) dans le dossier du site web. Il peut uploader des fichiers mais ne peut pas remonter à la racine du serveur pour voir les fichiers système.

Le Technicien : C'est l'administrateur. Pour plus de sécurité, on configure souvent son accès SSH pour qu'il ne soit possible que depuis une adresse IP spécifique (son poste de travail technique) afin d'éviter qu'un pirate ne tente de forcer l'entrée.

Ce tableau montre bien que l'isolation n'est pas seulement réseau (le segment 10.0.0.0), mais aussi **applicative** (on segmente les usages).

Partie B :

1) Format de nommage des fichiers

Pour que n'importe quel membre du personnel puisse identifier le document sans réfléchir, voici le format recommandé :

Modèle : Secteur - JJ-MM-AAAA - HHhMM.pdf

- **Exemple 1** : Labo1 - 25-03-2026 - 08h30.pdf
- **Exemple 2** : Pharmacie3 - 25-03-2026 - 17h15.pdf
- **Exemple 3** : Secrétariat - 26-03-2026 - 09h00.pdf

Pourquoi ce choix ?

1. **Priorité au Secteur** : Quand on cherche un fichier dans une liste, l'œil humain cherche d'abord "qui" est concerné.
2. **Date familière** : Le format Jour-Mois-Année est le standard administratif en France.
3. **Heure explicite** : L'utilisation du "h" (08h30) évite toute confusion avec d'autres chiffres

2) Déploiement du serveur FTP de fichiers

Pour mettre cela en place sur votre serveur de fichiers via xampp, voici comment organiser les droits selon ce nouveau format :

Utilisateur	Action sur le fichier	Dossier cible
Rapporteur	Création + Lecture	/Secteur_Origine/
Employé	Lecture seule	/Secteur_Origine/
Directeur	Lecture seule	Tous les dossiers

2.1 Installation et paramétrage

Le service FTP est activé directement sur le serveur.

(Dans Cisco Packet Tracer : onglet *Services* > *FTP* ; en situation réelle : via **IIS** sous Windows Server ou **vsftpd** sous Linux).

Configuration réalisée :

- Activation du service FTP sur le serveur **10.0.0.2**
 - Création de comptes pour les **rapporteurs** (autorisation d'envoi de fichiers)
 - Création de comptes pour les **employés** (accès en lecture uniquement)
-

2.2 Vérification de l'upload par un rapporteur

Un rapporteur se connecte au serveur FTP à l'aide de ses identifiants.

Il dépose ensuite un compte rendu en respectant la convention de nommage définie.

2.3 Vérification du téléchargement par un employé

Un employé se connecte au serveur FTP avec son compte personnel et télécharge le document souhaité.

3. Limitation des accès par secteur

3.1 Principe

Afin de restreindre l'accès aux documents, chaque employé ne peut consulter que les fichiers de son secteur.

Cela est réalisé grâce à une organisation des répertoires par service.

Arborescence mise en place :

/comptes-rendus/

├── Labo1/

├── Labo2/

├── Pharmacie1/

├── Secretariat/

3.2 Gestion des permissions

Chaque utilisateur est associé à un dossier spécifique correspondant à son service :

- Rapporteur : droits **lecture + écriture** sur son dossier
- Employé : droits **lecture seule** sur son dossier
- Accès interdit aux autres répertoires

3.3 Tests réalisés

- Un utilisateur du **Labo1** accède uniquement à son dossier ✓
- Tentative d'accès aux dossiers **Labo2** ou **Pharmacie** refusée ✓

4. Accès du Directeur Général

4.1 Principe

Le Directeur Général doit pouvoir consulter l'ensemble des comptes rendus, quel que soit le secteur.

4.2 Configuration

Création d'un compte spécifique avec :

- Accès en **lecture** sur tous les dossiers
- Aucun droit de modification
- Accès autorisé uniquement depuis son poste (192.168.1.X)

4.3 Vérification

- Consultation de plusieurs dossiers ✓
- Téléchargement des fichiers ✓

5. Sécurisation du serveur de fichiers

Le serveur (10.0.0.2) est déjà isolé dans le réseau interne **10.0.0.0/8**.
Des mesures supplémentaires sont mises en place :

- Filtrage via le routeur :
 - Autorisation des ports FTP (21 et 20 / passif)
 - Blocage des autres ports
- Désactivation de l'accès anonyme
- Authentification obligatoire
- Mise en place de mots de passe robustes (longueur + complexité)

6. Synthèse et architecture réseau

L'infrastructure GSB est organisée de la manière suivante :

- Réseau utilisateurs : **172.30.X.X/24**
- Réseau serveurs : **10.0.0.0/8**
 - Serveur Web/FTP : 10.0.0.1
 - Serveur de fichiers : 10.0.0.2
- Routeur central assurant :
 - la communication entre les réseaux
 - le filtrage des accès

7. Vidéo de démonstration

Une démonstration a été réalisée avec OBS Studio.

Elle présente :

- Connexion au serveur web/FTP
- Dépôt d'un fichier par un rapporteur
- Téléchargement par un utilisateur autorisé
- Refus d'accès vers un autre secteur
- Accès global du Directeur

Partie C — Gestion des sauvegardes

1. Éléments à sauvegarder

Élément	Contenu	Fréquence
Serveur web/FTP	Fichiers + configuration	Quotidienne
Serveur de fichiers	Comptes rendus	Quotidienne
Routeur	Configuration	Hebdomadaire
Comptes utilisateurs	Identifiants FTP	Hebdomadaire
Logs	Journaux d'accès	Mensuelle

2. Procédure de sauvegarde

2.1 Serveur web/FTP

Sauvegarde des fichiers du site et des données FTP vers un espace sécurisé.

2.2 Serveur de fichiers

Copie quotidienne des comptes rendus vers un stockage dédié.
Automatisation possible via script (ex : tâche planifiée ou cron).

2.3 Configuration du routeur

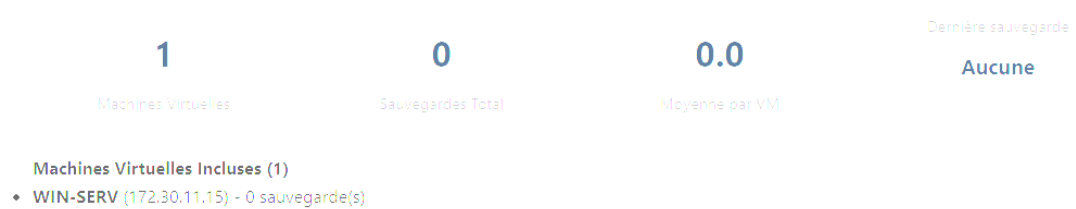
Export de la configuration avec :

copy running-config tftp

3. Rapport des sauvegardes

Type : Toutes les sauvegardes

Date de génération : 26/04/2026 18:33:45



Conclusion:

Ce TP a permis d'améliorer de manière notable la sécurité et l'organisation de l'infrastructure réseau GSB. Plusieurs actions importantes ont été réalisées :

- Mise en place d'une isolation du serveur Web/FTP au sein d'un réseau dédié **10.0.0.0/8**, sécurisé par un routeur assurant le filtrage des accès
- Déploiement d'un serveur FTP dédié au stockage et à la gestion des comptes rendus de réunions
- Mise en œuvre d'un contrôle d'accès précis : chaque utilisateur ne peut consulter que les documents correspondant à son secteur
- Attribution d'un accès global au Directeur Général, lui permettant de consulter l'ensemble des comptes rendus
- Application de mesures de sécurité identiques à celles du serveur Web/FTP pour protéger le serveur de fichiers
- Mise en place d'un système de sauvegardes régulières avec suivi des opérations sur les éléments critiques du réseau